

Mapeo de Preguntas a Requisitos Normativos y Marcos de Referencia

Nota: este mapeo es orientativo y debe adaptarse al contexto regulatorio concreto de cada organización.

Leyenda de marcos

- NIS2: Directiva (UE) 2022/2555 y su transposición en España.
- DORA: Reglamento (UE) 2022/2554 sobre resiliencia operativa digital.
- ENS: Esquema Nacional de Seguridad.
- ISO 27001/27002: Sistemas de gestión de seguridad de la información.
- NIST CSF: NIST Cybersecurity Framework.
- Otros: normativa sectorial específica (financiera, sanitaria, etc.).

Tabla de mapeo

Pregunta	Tema resumido	NIS2	DORA	ENS	ISO 27001/27002	NIST CSF (función/categoría)	Comentarios
P1	Estrategia formal de ciberseguridad	Art. 21 (políticas y medidas)	Art. 5, 6 (marco de gobernanza)	Principios básico y mínimo	Cl. 5 (Liderazgo), A.5 (Políticas)	ID.GV-1, ID.GV-2	Estrategia como base de gobernanza.
P2	Plan de acción y métricas	Art. 21, 23	Art. 6, 11 (estrategias y planes)	Planificación de seguridad	Cl. 6 (Planificación), A.5	ID.GV-3, ID.BE-4	Hoja de ruta y objetivos de seguridad.
P3	Marcos de referencia utilizados	Implícito	Implícito	ENS completo	Estructura global	ID.GV-2	Alineamiento multipolar.
P4	Grado de cumplimiento normativo	Art. 20–24	Art. 4–14	ENS (cumplimiento)	Cl. 9 (Evaluación)	ID.SC-4, ID.RM-1	Autoevaluación del cumplimiento.
P5	Inventario de activos	Art. 21 (medidas técnicas organizativas)	Art. 8 (gestión de TI)	Medida de organización, Explot.	A.5, A.8 (Inventario de activos)	ID.AM-1, ID.AM-2	Visibilidad de activos.
P6	Clasificación de activos	Art. 21	Art. 8	ENS (clasificación de la info)	A.8 (Clasificación de la información)	ID.AM-2	Criticidad y protección proporcional.
P7	Gestión de superficie de ataque	Art. 21, 23	Art. 8, 11	Medidas técnicas (protección)	A.8, A.12, A.13	ID.AM-3, PR.AC-5	Exposición de activos.
P8	Revisión de activos críticos	Art. 21	Art. 11	Revisiones periódicas ENS	Cl. 9, A.12	ID.RA-3, ID.RM-2	Ciclo de revisión.
P9	Aplicación del modelado de amenazas	Art. 21	Art. 8, 11	ENS (análisis de riesgos)	A.6, A.8, A.12	ID.RA-1, ID.RA-3, PR.IP-3	Evaluación proactiva de amenazas.

P10	Metodologías de modelado de amenazas	Art. 21	Art. 11	ENS (metodologías de análisis)	A.6 (Planificación de riesgos)	ID.RA-1	Adopción de marcos estructurados.
P11	Cobertura de modelos de amenazas	Art. 21, 23	Art. 8, 11	ENS (alcance de medidas)	A.8, A.12	ID.RA-3	Porcentaje de sistemas analizados.
P12	Frecuencia de actualización de modelos	Art. 21, 23	Art. 11	ENS (revisión periódica)	Cl. 9	ID.RA-3, PR.IP-7	Dinamismo vs. foto fija.
P13	Integración en SDLC y CI/CD	Art. 21	Art. 8, 11	ENS (seguridad en desarrollo)	A.14 (Seguridad en desarrollo y soporte)	PR.IP-3, PR.IP-8	DevSecOps y automatización.
P14	Participación de áreas en modelado	Art. 21, 24	Art. 5, 6	ENS (organización de seguridad)	A.5 (Organización interna)	ID.GV-1, PR.AT-3	Colaboración multidisciplinar.
P15	Comunicación de resultados de amenazas	Art. 23, 24	Art. 14	ENS (documentación, informes)	Cl. 7, A.5, A.16	RS.CO-1, RS.CO-2	Lenguaje para negocio y TI.
P16	Métricas técnicas monitorizadas	Art. 21, 23	Art. 11	ENS (monitorización)	A.12, A.16	DE.CM-1, PR.MA-1	Base para indicadores operativos.
P17	SLAs / SLOs de detección y respuesta	Art. 21, 23	Art. 11	ENS (gestión de incidentes)	A.12, A.16	DE.CM-4, RS.RP-1	Compromisos de rendimiento.
P18	Cuantificación económica del riesgo	Art. 21	Art. 6, 11	ENS (análisis de riesgos)	Cl. 6, Cl. 8	ID.RM-1, ID.RM-2	VaR, pérdidas estimadas.

P19	Reporting al Consejo	Art. 20, 21	Art. 5, 6	ENS (responsabilidad de dirección)	Cl. 5 (Liderazgo)	ID.GV-1, ID.GV-3	Responsabilidad de la alta dirección.
P20	Indicadores reportados a la alta dirección	Art. 20-24	Art. 6, 11	ENS (seguimiento y control)	Cl. 9, Cl. 10	ID.RM-1, RS.CO-2	Contenido del reporting.
P21	Herramientas de gestión de vulnerabilidades	Art. 21, 23	Art. 8, 11	ENS (protección de sistemas)	A.12, A.13	PR.IP-12, DE.CM-8	Capacidades técnicas.
P22	Tiempo de remediación de vulnerabilidades críticas	Art. 21	Art. 11	ENS (criterios de seguridad)	A.12, A.13	PR.IP-12, RS.MI-1	Plazo de corrección y prioridades.
P23	Atención a vulnerabilidades explotadas activamente	Art. 21, 23	Art. 11	ENS (gestión de amenazas)	A.12, A.16	DE.CM-1, ID.RA-1	Cruce con inteligencia de amenazas.
P24	Evaluación de riesgos de terceros	Art. 21, 23	Art. 28 (proveedores TIC críticos)	ENS (relación con terceros)	A.15 (Relaciones con proveedores)	ID.SC-3, PR.AT-3	Cadena de suministro.
P25	Cláusulas de ciberseguridad en contratos	Art. 21, 23	Art. 28	ENS (contratación)	A.15	ID.SC-3, PR.AT-3	Requisitos contractuales.
P26	Plan de respuesta a incidentes	Art. 23, 24	Art. 11	ENS (respuesta a incidentes)	A.16 (Gestión de incidentes)	RS.RP-1, RS.RP-2	Preparación formal.

P27	Notificación a autoridades	Art. 23, 30	Art. 19	ENS (comunicación de incidentes)	A.16	RS.CO-1, RS.CO-2	Obligaciones de notificación.
P28	Planes de continuidad y DR	Art. 21	Art. 11, 15	ENS (operación continua)	A.17 (Aspectos de continuidad)	PR.IP-9, RC.IM-1	Resiliencia operativa.
P29	Definición de RTO y RPO	Art. 21	Art. 11, 15	ENS (continuidad)	A.17	PR.IP-9, RC.RP-1	Objetivos de recuperación.
P30	Dotación de personal de ciberseguridad	Art. 20, 21	Art. 5, 6	ENS (recursos)	Cl. 7, A.7 (Recursos humanos)	ID.GV-2, PR.AT-4	Capacidades internas.
P31	Dificultades para cubrir puestos de ciberseguridad	Art. 20	Art. 5	ENS (recursos)	Cl. 7	ID.GV-2, PR.AT-4	Brecha de talento.
P32	Concienciación de empleados	Art. 21	Art. 6	ENS (sensibilización)	A.6, A.7 (Concienciación)	PR.AT-1, PR.AT-2	Cultura de seguridad.
P33	Formación en modelado de amenazas	Art. 21	Art. 6, 11	ENS (formación específica)	A.6, A.7	PR.AT-3	Capacidad analítica avanzada.
P34	Prioridades de inversión	Art. 21, 23	Art. 11	ENS (planificación)	Cl. 6, Cl. 7	ID.RM-1, PR.IP-1	Alineamiento de recursos.
P35	Percepción del modelado de amenazas	Art. 21	Art. 8, 11	ENS (análisis de riesgos)	A.6	ID.RA-1	Cultura sobre el enfoque.

P36	Interés en iniciativas sectoriales /nacionales	Art. 21, 23	Art. 4, 6	ENS (colaboración)	Cl. 4, Cl. 7	ID.BE-4, RS.CO-3	Cooperación e intercambio.
P37	Comentarios abiertos	No directo	No directo	No directo	Cl. 9 (Mejora continua)	Todas (insights cualitativos)	Insumos para mejora normativa.

Este mapeo puede expandirse con referencias más precisas (artículos concretos del ENS, guías CCN, etc.) en futuras versiones.